SSL/TLS Verifier

Equipo: IPV6
Saira Salazar Nuñez
Hernan Rios Iglesias

Hackathon Talento Tech
RETO 2: Sistema de Análisis de Configuración TLS y Riesgo de Exposición de Servicios Web

Pereira - Risaralda
28 de marzo de 2026

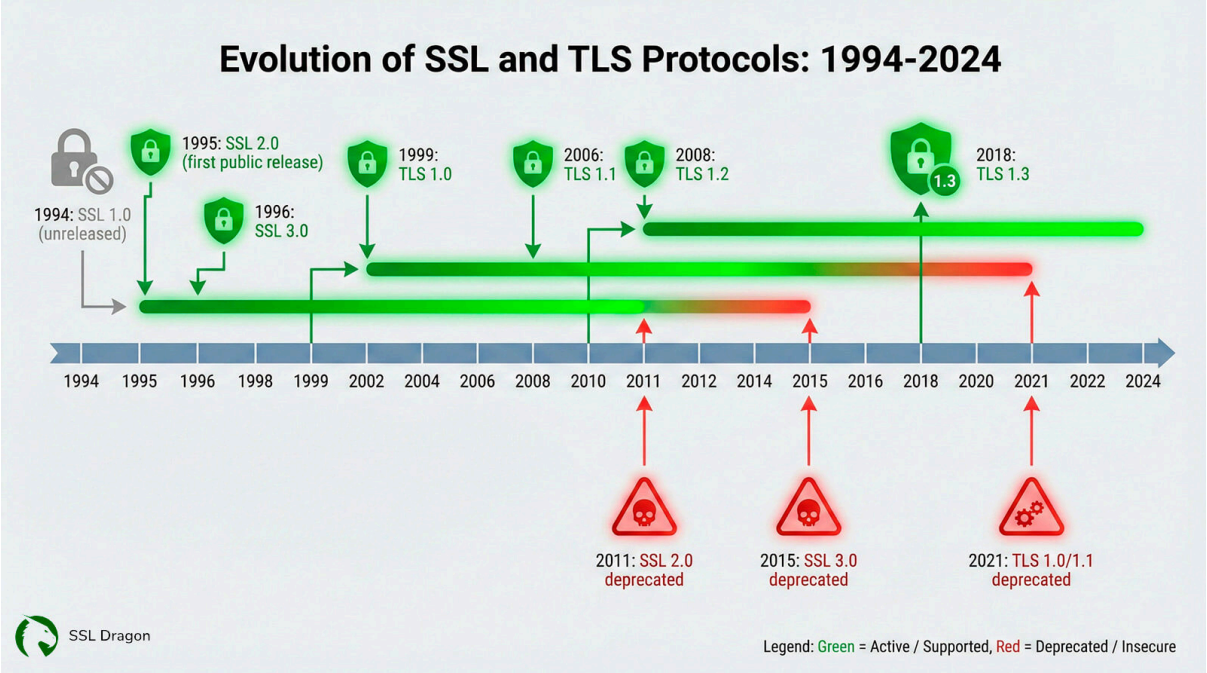
Introducción

El presente documento tiene como propósito describir el diseño, desarrollo e implementación del aplicativo **SSL/TLS Verifier**, detallando su estructura, las tecnologías empleadas y la lógica de funcionamiento utilizada para analizar configuraciones SSL/TLS e identificar riesgos de exposición en servicios web.

Marco conceptual:TLS

Transport Layer Security (TLS) es un protocolo criptográfico diseñado para garantizar la confidencialidad, integridad y autenticidad de la información intercambiada entre clientes y servidores a través de redes como Internet. Su uso es fundamental en servicios web, APIs y plataformas digitales que requieren proteger las comunicaciones frente a accesos no autorizados o alteraciones en tránsito.

Evolución de SSL a TLS



El uso de TLS no garantiza por sí solo una comunicación completamente segura entre el cliente y el servidor. Aunque una conexión se muestre como segura, esto no implica necesariamente que su configuración sea adecuada. El uso de versiones obsoletas del protocolo, configuraciones débiles o implementaciones incorrectas puede generar riesgos importantes de seguridad. En este contexto, **SSL/TLS Verifier** surge como una herramienta orientada a automatizar el análisis de la configuración de un servidor, facilitando la identificación de versiones inseguras y apoyando la evaluación de su nivel de exposición.

Desarrollo y construcción del aplicativo

Para el desarrollo de la aplicación se planteó una metodología orientada a facilitar una construcción modular, clara y organizada. Esta metodología permitió estructurar el proyecto desde la definición del problema hasta la presentación final de los hallazgos obtenidos. Las etapas consideradas fueron las siguientes:

- Definición objetivos.
- Definición de herramientas, alcance y pruebas.
- Definición checklist de verificación de conexión segura.
- Establecimiento de una tabla de priorización de hallazgos y recomendaciones.
- Definición del formato de presentación de hallazgos.
- Identificación de dependencias de la aplicación.
- Normatividad.

1. Objetivos

Diseñar una aplicación end-to-end en línea de comandos (CLI) que permita analizar uno o varios dominios o direcciones IP, verificando las versiones de TLS habilitadas, la presencia de protocolos obsoletos, configuraciones inseguras o no recomendadas, y el estado general del servidor evaluado. Como resultado, la herramienta debe entregar al usuario una visión clara, simplificada y comprensible del estado de seguridad de la conexión con el servidor analizado.

2. Herramientas, alcance y pruebas

Para el desarrollo de la aplicación se definió el uso de dos herramientas ampliamente reconocidas en el análisis de configuraciones SSL/TLS: **testssl.sh** y **nmap**. Ambas ofrecen capacidades técnicas robustas para el análisis de servicios expuestos, aunque sus resultados están orientados principalmente a usuarios con conocimientos técnicos avanzados. Por esta razón, se decidió integrarlas en una solución que permitiera traducir dichos resultados en información más clara y útil para el usuario final.

testssl.sh es una herramienta diseñada para auditar servidores y verificar la configuración de protocolos, cifrados y posibles debilidades de seguridad en servicios SSL/TLS. Su alcance dentro de la solución propuesta resulta fundamental, ya que permite identificar versiones habilitadas, configuraciones inseguras, características del servicio y otros elementos relevantes para la evaluación de la postura de seguridad del objetivo analizado.

Con el fin de validar su funcionamiento, se realizaron pruebas con diferentes direcciones IP en entornos controlados y objetivos autorizados. A partir de estas pruebas, se concluyó que la herramienta ofrece resultados consistentes, confiables y adecuados para su integración dentro del aplicativo.

Por su parte, **nmap** es una herramienta de código abierto ampliamente utilizada para exploración de redes, descubrimiento de servicios y apoyo en auditorías de seguridad. En esta solución, su uso complementa el análisis realizado por testssl.sh, aportando visibilidad sobre puertos abiertos y servicios activos, lo que permite contextualizar mejor la evaluación del servidor y apoyar la identificación de posibles alertas relacionadas con la exposición del servicio.

También se realizaron pruebas con nmap sobre direcciones IP autorizadas y ambientes de prueba, con el fin de validar su utilidad en la detección de puertos y servicios relevantes. Debido a su amplia adopción en el campo de la ciberseguridad y a los resultados obtenidos durante las pruebas, se determinó que esta herramienta constituye un apoyo valioso dentro del desarrollo de la aplicación.

3. Checklist de verificación de conexión segura

- Validar disponibilidad del host y exposición del servicio TLS.
- Identificar las versiones del protocolo habilitadas.
- Verificar que no existan versiones obsoletas como SSLv2, SSLv3, TLS 1.0 o TLS 1.1.
- Revisar las suites criptográficas soportadas y descartar configuraciones débiles o heredadas.
- Validar el certificado digital, su vigencia, coincidencia con el dominio y cadena de confianza.
- Comprobar mecanismos seguros de intercambio de claves y soporte de forward secrecy.
- Identificar vulnerabilidades o debilidades criptográficas conocidas reportadas por la herramienta.
- Revisar controles complementarios del servicio web, como redirección a HTTPS y HSTS.
- Clasificar los hallazgos según criticidad y definir recomendaciones de remediación.
- Consolidar un estado general de seguridad del servidor evaluado.

4. Tabla de priorización de hallazgos y recomendaciones

Severidad	Hallazgo	Descripción / impacto	Recomendación
Crítico	SSLv2 o SSLv3 habilitado	Expone el servicio a protocolos criptográficamente inseguros y obsoletos.	Deshabilitar completamente SSLv2 y SSLv3. Permitir únicamente TLS 1.2 y/o TLS 1.3.
Crítico	TLS 1.0 habilitado	Permite el uso de una versión obsoleta del protocolo, con riesgo de degradación de seguridad y no alineada con buenas prácticas actuales.	Deshabilitar TLS 1.0 y restringir el servicio a TLS 1.2 o superior.

Crítico	TLS 1.1 habilitado	Mantiene compatibilidad con una versión heredada del protocolo y amplía la superficie de exposición.	Deshabilitar TLS 1.1 y restringir el servicio a TLS 1.2 o superior.
Crítico	NULL ciphers habilitados	Permiten suites sin cifrado efectivo, comprometiendo la confidencialidad de la comunicación.	Deshabilitar suites NULL y permitir solo cifrados robustos.
Crítico	Cifrados anónimos habilitados	Eliminan garantías de autenticación del servidor y facilitan ataques de intermediario.	Deshabilitar suites anónimas y exigir autenticación mediante certificado válido.
Crítico	Certificado autofirmado	El servicio no ofrece una cadena de confianza verificable para clientes externos.	Reemplazar por un certificado emitido por una CA confiable.
Crítico	El certificado no coincide con el host	El nombre del certificado no corresponde al dominio o IP analizada, afectando la autenticidad del servicio.	Emitir o instalar un certificado cuyo CN/SAN coincida con el host evaluado.
Crítico	SAN ausente en el certificado	Puede generar fallas de validación y problemas de compatibilidad con clientes modernos.	Incluir subjectAltName válido con los dominios esperados.
Alto	Suites débiles o heredadas (CBC obsoleto, 3DES, RC4, EXPORT, DES)	Reducen la fortaleza criptográfica del canal y pueden facilitar ataques conocidos o degradación de seguridad.	Deshabilitar suites débiles y priorizar suites modernas AEAD, preferiblemente con GCM o ChaCha20.

Alto	Clave RSA de 1024 bits	Longitud de clave insuficiente frente a recomendaciones modernas.	Migrar a RSA de al menos 2048 bits o preferir certificados ECDSA cuando aplique.
Alto	Ausencia de Forward Secrecy	Si la clave privada del servidor se ve comprometida, sesiones anteriores podrían quedar expuestas.	Priorizar suites con ECDHE y configuraciones modernas de intercambio de claves.
Alto	Vulnerabilidad confirmada por testssl.sh (por ejemplo Heartbleed, LOGJAM, SWEET32, POODLE, CRIME, según aplique)	Indica exposición directa a una debilidad conocida del protocolo o de la configuración.	Aplicar remediación específica: actualizar librerías, deshabilitar protocolos/cifrados vulnerables y revalidar la configuración.
Medio	El servidor no define preferencia de cifrados	Puede permitir que el cliente negocie suites menos robustas de las deseadas.	Configurar el orden de preferencia de cifrados del lado del servidor.
Medio	HSTS no configurado	El usuario podría seguir accediendo inicialmente por HTTP o ser expuesto a downgrade a conexiones no seguras.	Habilitar HSTS en entornos HTTPS estables y productivos.
Medio	No se encontró mecanismo de revocación (OCSP/CRL)	Dificulta verificar si el certificado ha sido revocado.	Configurar OCSP o CRL y validar su correcta publicación.
Medio	Compresión HTTP/TLS con posible exposición a BREACH/CRIME	Puede facilitar ataques de recuperación de información sensible en contextos específicos.	Revisar el uso de compresión y evitarla en respuestas sensibles o configuraciones vulnerables.
Medio	Cadena de certificados incompleta	Algunos clientes no podrán validar correctamente el certificado.	Instalar la cadena completa de confianza en el servidor.

Medio	Puerto TLS esperado cerrado o servicio no accesible	Impide la validación del servicio y puede indicar indisponibilidad o configuración incompleta.	Verificar publicación del servicio, apertura de puertos y conectividad de red.
Bajo	TLS 1.3 no habilitado	No implica por sí solo una configuración insegura si TLS 1.2 está bien implementado, pero limita adopción de una versión más moderna.	Evaluar compatibilidad y habilitar TLS 1.3.
Bajo	Banner del servidor expuesto	Revela información tecnológica útil para perfilamiento del servicio.	Minimizar o suprimir banners innecesarios.
Bajo	Ausencia de redirección HTTP → HTTPS	Puede generar una experiencia inconsistente y exponer intentos de conexión inicial en HTTP.	Redirigir tráfico HTTP a HTTPS cuando el servicio web lo requiera.
Informativo	TLS 1.2 habilitado	Indica soporte de una versión vigente y ampliamente aceptada.	Mantener TLS 1.2 mientras se migra progresivamente a TLS 1.3.
Informativo	TLS 1.3 habilitado	Refleja adopción de una versión moderna del protocolo.	Mantener la configuración y validar compatibilidad con suites y curvas recomendadas.

5. Formato de presentación de hallazgos

La salida final del aplicativo se genera en un reporte HTML estructurado, el cual consolida los resultados del análisis TLS en una interfaz clara y legible. El informe contiene cuatro bloques principales: identificación del servidor analizado y nivel de exposición general, resumen ejecutivo de hallazgos, tabla de protocolos SSL/TLS detectados y tabla detallada de hallazgos inseguros con su respectiva evidencia y recomendación.

La estructura del reporte fue diseñada para facilitar la interpretación del diagnóstico de seguridad, permitiendo al usuario reconocer de forma rápida el estado de la configuración

evaluada, la criticidad de los problemas encontrados y las acciones sugeridas para su remediación.

Si quieres, el siguiente paso puede ser redactar el apartado de arquitectura o flujo de funcionamiento del aplicativo, que conecta muy bien después de esta sección.

6. Dependencias de la aplicación

Para ejecutar SSL/TLS Verifier, el usuario debe contar con las siguientes dependencias instaladas en el sistema:

- bash
- nmap
- testssl.sh

7. Normatividad

La solución toma como base de referencia ISO/IEC 27001, ISO/IEC 27002 e ISO/IEC 27005 como marco de gestión y control de seguridad de la información; NIST SP 800-52 Rev. 2 y NIST CSF 2.0 como lineamientos para configuración segura y gestión del riesgo; RFC 8446 y RFC 5246 como sustento técnico del protocolo TLS; y guías de buenas prácticas como OWASP Transport Layer Security Cheat Sheet y Mozilla Server Side TLS Configuration Guide. Adicionalmente, pueden considerarse PCI DSS v4.0 y los Baseline Requirements del CA/Browser Forum cuando el servicio analizado pertenezca a contextos de pago electrónico o uso de certificados públicamente confiables.

Hallazgo	Referencia normativa/técnica	Tipo de relación
TLS 1.0 habilitado	RFC 8996; NIST SP 800-52 Rev. 2; OWASP TLS Cheat Sheet	Incumplimiento técnico directo
TLS 1.1 habilitado	RFC 8996; NIST SP 800-52 Rev. 2; OWASP TLS Cheat Sheet	Incumplimiento técnico directo
NULL ciphers	OWASP TLS Cheat Sheet; RFC 9325	Incumplimiento técnico directo
Cifrados anónimos	OWASP TLS Cheat Sheet; RFC 9325	Incumplimiento técnico directo
CBC obsoleto	OWASP TLS Cheat Sheet; RFC 9325	Desviación de mejores prácticas

Sin preferencia de cifrados	NIST SP 800-52 Rev. 2; RFC 9325	Desviación de hardening
SAN ausente	RFC 2818; RFC 6125; OWASP	Incumplimiento técnico directo
Hostname mismatch	RFC 2818; RFC 6125; OWASP	Incumplimiento técnico directo
Certificado autofirmado	OWASP; guía pública NIST sobre certificados	Desviación fuerte / no confianza pública
RSA 1024	OWASP TLS Cheat Sheet	Incumplimiento de fortaleza recomendada
HSTS ausente	OWASP TLS Cheat Sheet; OWASP HSTS; RFC 6797	Desviación de hardening web
BREACH / compresión	OWASP TLS Cheat Sheet	Desviación de hardening
TLS 1.3 ausente	NIST SP 800-52 Rev. 2; OWASP; RFC 8446	Mejora recomendada
Banner expuesto	ISO 27002 enfoque general	Observación de hardening

Referencia

Open Worldwide Application Security Project. (s. f.). *Transport Layer Security Cheat Sheet*. OWASP Cheat Sheet Series.

Open Worldwide Application Security Project. (s. f.). *HTTP Strict Transport Security Cheat Sheet*. OWASP Cheat Sheet Series.

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements.*

International Organization for Standardization. (2022). ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls.

International Organization for Standardization. (2022). ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection — Guidance on managing information security risks.

https://github.com/Aragxt/SSL-TLS-Verifier.git